CARDS AND EVIDENCE PACK | DAY 2, SESSION 3: DATA PROTECTION IN BOTH DIRECTIONS

Cold Front

A ransomware tabletop for the University of Minnesota

Print single-sided. Cut the attack cards, the twist card, and the lifeline tokens along the frames.
Fold the role tents on the dotted line.
Keep pages marked FACILITATOR ONLY out of the teams' hands until the debrief.

Contents (page numbers as printed in the footer)

1	Situation Report 1 (Inject 1)
2	Ransom note
3	Evidence E-01: the phishing email
4	Evidence E-02: help desk ticket log
5	Evidence E-03: the shared mailbox
6 to 9	Role tents
10 to 15	Attack cards 1 to 6
16	Inject 2: the 07:00 message
17	Twist card: Burn the keys
18	Lifeline tokens
19	Scoreboard poster
20	Attacker's Diary (facilitator only)
21	The as-is outcome (facilitator only)

Everything in this pack is fictional and built for training: the systems, the accounts, the dates, the attacker, and the events. No real person is depicted. Gamut Technology Services for the University of Minnesota.

INJECT 1 | READ ALOUD AT 0:16

Situation Report 1

University IT Major Incident, reference INC-2026-1114-001 (fictional)

Issued: Saturday, November 14, 2026, 04:35 Central Time **Status:** Major incident declared **Incident commander:** on-call infrastructure manager

What we know

Time	Observation
02:14	Files on FS-TC-01 through FS-TC-04 began changing extension to .coldfront. A file named COLD_FRONT_README.txt appeared in the root of every top-level share.
02:30 to 03:00	ORA-FIN-01 and ORA-FIN-02 reported data file corruption; the departmental finance application is down. SQL-DEPT-03 is unreachable.
03:05	The local storage pool on MABS-TC-01 shows the same extension change. The MABS console will not start.
03:40	Night staff at the animal health imaging unit cannot open studies. The help desk receives 11 tickets in 20 minutes.
04:10	The on-call storage engineer confirms encryption on all four file servers and finds the ransom note.
04:20	The Azure portal shows 12 virtual machines in the student services web tier unresponsive. The backup items view for rsv-cus-infra-01 is empty.
04:28	Storage account stumnbkpimages01 cannot be found in the portal.
04:35	Major incident declared. The university security office is engaged.
04:50	Account adm-stor-07 is disabled after sign-in logs show activity from an unfamiliar network since October 29.

What we do not know yet

The full scope inside Azure. Whether data was copied out. Which backup copies survived, and in what state. Whether the attacker still has a way back in.

> **Facilitator:** read this in a flat, operational voice. Then pick up the ransom note and change your voice. Hand each team the ransom note and the help desk log. Ask one question only: *What do you want to know first?* Take two answers and move on.

EVIDENCE | FOUND IN THE ROOT OF EVERY SHARE

COLD_FRONT_README.txt

```
================================================
                  COLD FRONT
================================================

Your network has been visited.

Your files are encrypted. Your backups are gone.
We have copies of your research data and your
finance records.

We have watched you for two weeks. We know your
schedule. We know where you keep your keys.

To recover your files you will need our tool.
Price and instructions: contact us through the
address in COLD_FRONT_CONTACT.txt within 72 hours.

Do not try to restore from backup.
There is no backup.

Do not contact law enforcement.

------------------------------------------------
Your personal ID: CF-8841-UMN-2614-TC
================================================
```

Facilitator: pause after "There is no backup." Ask the room whether that is true. Do not answer. Then: "Do not contact law enforcement" is what every ransom note says; Microsoft Learn's guidance for a United States organization is the opposite, through the FBI's IC3. The contact file is a prop; no address exists. The university's own policy decides how a ransom demand is handled, never the infrastructure team alone.

SIXTEEN DAYS BEFORE THE ATTACK

Evidence E-01: the phishing email

Field	Value
From	Research Storage Support <quota-notices@umn-storage-quota.example>
To	(a storage administrator's university mailbox)
Sent	Thursday, October 29, 2026, 13:52 Central Time
Subject	Action required: research share quota exceeded (rds-north/cbs-lab-12)

Hello,

Your research storage allocation **rds-north/cbs-lab-12** has exceeded **98%** of its quota. Users in this allocation will lose write access at **17:00 today** unless the allocation is extended.

To extend the allocation, download and run the **Quota Reclaim Tool** from the Research Storage Support portal. The tool requires your administrator credentials to apply the change.

[Download Quota Reclaim Tool]

Thank you for keeping research moving.
Research Storage Support

What happened next (facilitator background)

The administrator ran the tool on a workstation where the privileged account adm-stor-07 was signed in. The tool stole the session. The attacker used that session from an unfamiliar network for sixteen days before the first destructive action. Nothing about the backup vaults was ever "hacked"; every later step was a legitimate portal operation performed by a legitimate account.

Red flags for the debrief, if the room wants them

Flag	Why it matters
Urgency with a deadline	Pressure replaces verification.
A lookalike sender domain	The university's real support never writes from an outside domain.
A download that needs administrator credentials	No quota change requires running a tool with privileged credentials on an administrator's workstation.
A privileged account signed in on a workstation used for email	Microsoft Learn's ransomware guidance prioritizes protecting privileged roles, starting with IT administrators.

SATURDAY 03:41 TO 04:28

Evidence E-02: help desk ticket log

Ticket	Time	Reported by (role)	Summary
INC0462281	03:41	Imaging technologist, animal health imaging unit	Cannot open studies. Files show a .coldfront extension.
INC0462282	03:44	Imaging technologist, same unit	Viewer reports "file corrupted" on every study opened since 02:30.
INC0462283	03:52	Overnight digitization operator, campus libraries	Scan drop folder on FS-TC-03 unreachable. Archive ingest paused.
INC0462284	03:58	Facilities dispatch	Work order printer queue hosted on FS-TC-01 offline.
INC0462285	04:02	Finance application on-call support	ORA-FIN-01 listener down. Alert log shows ORA-01578 data block corrupted.
INC0462286	04:06	Residence hall front desk	Shared drive missing from every desk computer.
INC0462287	04:09	Research computing liaison, Research Institute North	Four project containers missing from the data lake listing.
INC0462288	04:12	Overnight digitization operator, campus libraries	Archive account stumnarchive340 still readable; delete attempts in the activity log that were not ours.
INC0462289	04:15	On-call storage engineer	All four file servers encrypted. Ransom note found. MABS-TC-01 local pool encrypted.
INC0462290	04:19	Student services web team	12 virtual machines unreachable. Backup items view for rsv-cus-infra-01 is empty.
INC0462291	04:28	Backup administrator	Storage account stumnbkpimages01 not found. Last seen Friday 17:00 in the estate export.

Reading the log: notice who noticed first (people who work nights), what they noticed (files, not alerts), and which ticket is good news. Ticket INC0462288 is the 340-year archive refusing to be deleted. Ask the teams why.

BACKUPALERTS@ | 1,412 UNREAD | LAST OPENED 41 DAYS AGO

Evidence E-03: the shared mailbox

Field	Value
Sent	Thursday, November 12, 2026, 03:06
Subject	Fired: Sev0 Azure Monitor alert | Delete Backup Data | rsv-cus-infra-01
Monitor condition	Fired
Severity	Sev0 (security)
Target resource	rsv-cus-infra-01 (Recovery Services vault)
Backup item	vm-stuweb-03 (Azure Virtual Machine)
Operation	Delete Backup Data
Initiated by	adm-stor-07
Description	Backup data for the item was deleted. The data is retained in the soft-deleted state and will be permanently deleted after the soft delete retention period.
Similar alerts	5 more alerts fired between 03:05 and 03:09: vm-stuweb-01, vm-stuweb-02, vm-stuweb-04, vm-itsvc-07, vm-rsrch-portal-02

Field	Value
Sent	Friday, November 13, 2026, 01:51
Subject	Fired: Sev0 Azure Monitor alert | Soft Delete Disabled for Vault | rsv-cus-infra-01
Monitor condition	Fired
Severity	Sev0 (security)
Target resource	rsv-cus-infra-01 (Recovery Services vault)
Operation	Soft delete disabled
Initiated by	adm-stor-07
Description	Soft delete has been disabled for this vault. Items deleted after this change are not retained in the soft-deleted state.

Reading the mailbox: both alerts are real, both are Sev 0, and neither can be switched off. Ask the teams what the action group should have done instead of sending email to a mailbox, and who should have been on the other end at 03:06 on a Thursday.

Direction 1: campus servers into Azure

Storage Lead

TEAM MAROON

TEAM MAROON

Storage Lead

Direction 1: campus servers into Azure

Vault settings: immutability, soft delete, MUA, alerts

Backup Operator

TEAM MAROON

TEAM MAROON

Backup Operator

Vault settings: immutability, soft delete, MUA, alerts

Oracle and SQL Server recovery

Database Lead

TEAM MAROON

TEAM MAROON

Database Lead

Oracle and SQL Server recovery

Identity, alert routing, the briefing to leadership

Security and Communications Liaison

TEAM MAROON

TEAM MAROON

Security and Communications Liaison

Identity, alert routing, the briefing to leadership

Direction 1: campus servers into Azure

Storage Lead

TEAM GOLD

TEAM GOLD

Storage Lead

Direction 1: campus servers into Azure

Vault settings: immutability, soft delete, MUA, alerts

Backup Operator

TEAM GOLD

TEAM GOLD

Backup Operator

Vault settings: immutability, soft delete, MUA, alerts

Oracle and SQL Server recovery

Database Lead

TEAM GOLD

TEAM GOLD

Database Lead

Oracle and SQL Server recovery

Identity, alert routing, the briefing to leadership

Security and Communications Liaison

TEAM GOLD

TEAM GOLD

Security and Communications Liaison

Identity, alert routing, the briefing to leadership

ATTACK CARD 1 OF 6 | FLIP WHEN THE FACILITATOR SAYS

Burn the recovery points 1

Saturday 02:14

Using the stolen administrator session, the attacker runs Stop backup with Delete backup data against every Azure VM protected in the Recovery Services vault.

Does your design keep the recovery points alive?

How to answer: your spokesperson names the control letter you are relying on, says whether it holds **fully**, holds **for a while**, or **does not hold**, and gives one sentence of why. Both teams declare before any points are awarded. Two points for a control that holds against an administrator with full rights; one point for a control that holds for a limited time or only until that administrator switches it off.

ATTACK CARD 2 OF 6 | FLIP WHEN THE FACILITATOR SAYS

Shrink the window

2

Saturday 02:21

The attacker edits the vault's backup policy so that daily recovery points are kept for 1 day instead of 30, and lets the older points age out.

Does your design refuse the shorter retention?

How to answer: your spokesperson names the control letter you are relying on, says whether it holds **fully**, holds **for a while**, or **does not hold**, and gives one sentence of why. Both teams declare before any points are awarded. Two points for a control that holds against an administrator with full rights; one point for a control that holds for a limited time or only until that administrator switches it off.

ATTACK CARD 3 OF 6 | FLIP WHEN THE FACILITATOR SAYS

Pull the safety net

3

Saturday 02:33

The attacker switches soft delete off for the vault, then undeletes and deletes again everything that was sitting in the soft-deleted state so it purges immediately.

Does your design stop soft delete from being switched off?

How to answer: your spokesperson names the control letter you are relying on, says whether it holds **fully**, holds **for a while**, or **does not hold**, and gives one sentence of why. Both teams declare before any points are awarded. Two points for a control that holds against an administrator with full rights; one point for a control that holds for a limited time or only until that administrator switches it off.

ATTACK CARD 4 OF 6 | FLIP WHEN THE FACILITATOR SAYS

Empty the Oracle shelf 4

Saturday 02:47

In the storage account that holds the Oracle RMAN images, the attacker removes the container's immutability policy and then deletes every blob in it.

Does your design keep the Oracle images?

How to answer: your spokesperson names the control letter you are relying on, says whether it holds **fully**, holds **for a while**, or **does not hold**, and gives one sentence of why. Both teams declare before any points are awarded. Two points for a control that holds against an administrator with full rights; one point for a control that holds for a limited time or only until that administrator switches it off.

ATTACK CARD 5 OF 6 | FLIP WHEN THE FACILITATOR SAYS

Delete the whole account 5

Saturday 02:52

To be thorough, the attacker deletes the entire storage account that holds the backup images.

Does your design stop the account from being deleted?

How to answer: your spokesperson names the control letter you are relying on, says whether it holds **fully**, holds **for a while**, or **does not hold**, and gives one sentence of why. Both teams declare before any points are awarded. Two points for a control that holds against an administrator with full rights; one point for a control that holds for a limited time or only until that administrator switches it off.

ATTACK CARD 6 OF 6 | FLIP WHEN THE FACILITATOR SAYS

Vanish

6

Saturday 02:00 to 03:00

Every one of these moves happened in a single hour, early on a Saturday. The attacker is counting on nobody looking until Monday morning.

Does your design wake someone up?

How to answer: your spokesperson names the control letter you are relying on, says whether it holds **fully**, holds **for a while**, or **does not hold**, and gives one sentence of why. Both teams declare before any points are awarded. Two points for a control that holds against an administrator with full rights; one point for a control that holds for a limited time or only until that administrator switches it off.

READ ALOUD AT 0:34

Inject 2: the 07:00 message

Field	Value
From	Associate Vice President, Information Technology
To	Infrastructure leadership; university security office
Sent	Saturday, November 14, 2026, 07:02 Central Time
Subject	Three questions before the 8:00 call

I have the President's chief of staff on a call at 8:00. I need three answers I can stand behind:

1. Can we recover without paying?
2. By when, and with how much data lost?
3. If the answer to the first question is no, what are our options?

Also: the note says our backups are gone. Last quarter we told the board we had immutable protection. I need to understand what that word meant and what it means now.

Call my mobile. Do not reply to this email.

CAMPUS ALERT, 07:15. Several campus file services and the departmental finance application are unavailable because of an IT security incident. Email, calendars, and the learning management system are operating normally. Updates will be posted to the IT status page every two hours.

07:40. A reporter from a local newsroom has emailed the university news service asking whether the university has been hit by ransomware and whether research data has been taken.

Facilitator: Move 3 answers questions 1 and 2. Question 3 is not the infrastructure team's decision, but they will need to explain the options to the people who decide. The reporter is a reminder that communications now run on a channel the attacker may be reading; ask who talks to whom, and how.

TWIST CARD | REVEAL AT 0:43 DURING MOVE 3

Burn the keys

!

Saturday 07:40

The MABS and MARS passphrase was written in a text file in the operations share on FS-TC-02. FS-TC-02 is encrypted. Without that passphrase, nothing protected by MABS or MARS can be restored, and Microsoft cannot recover it.

Where is your copy?

How to answer: say where your team's copy of the passphrase is, who can retrieve it, and how long that takes. If you do not have a copy, say what that means for the MABS and MARS backups, honestly, and what you would change so it never happens again. Two points for a copy that exists outside the blast radius; one point for an honest consequence and a fix.

CUT OUT. TWO PER TEAM. HAND ONE TO THE FACILITATOR FOR A HINT.

Lifeline tokens

LIFELINE

TEAM MAROON

Good for one hint from the facilitator.
The first two are free.
After that, each hint costs one Resilience Point.

LIFELINE

TEAM MAROON

Good for one hint from the facilitator.
The first two are free.
After that, each hint costs one Resilience Point.

LIFELINE

TEAM GOLD

Good for one hint from the facilitator.
The first two are free.
After that, each hint costs one Resilience Point.

LIFELINE

TEAM GOLD

Good for one hint from the facilitator.
The first two are free.
After that, each hint costs one Resilience Point.

Facilitator: hints are tiered in the Facilitator Guide, from a nudge to a near-answer. Give the lowest tier that gets the table moving again. Extra tokens for a third team can be photocopied; write the team name in by hand.

POST WHERE BOTH TEAMS CAN SEE IT

Resilience Scoreboard

	Move 1 (max 2)	Move 2 (max 12)	Move 3 (max 8)	Lifelines (minus 1 each beyond two)	Total (max 22)
Team Maroon					
Team Gold					

Move 2 by card

Card	1	2	3	4	5	6
Team Maroon						
Team Gold						

18 or more: Ice Dam Certified. Nothing got through.
12 to 17: Survived the Cold Front. Bruised, recoverable.
Under 12: Frostbitten but wiser. Everyone learned something, which is the point.

Roadmap items this exercise feeds into the capstone
Lock immutability on every vault after a planned clean-up window
Enhanced soft delete always-on, with the cost of days beyond 14 stated per vault
A Resource Guard in a separate subscription owned by a different team, same region, with just-in-time elevation
Locked time-based immutability with versioning on the Oracle and third-party image containers
Passphrase custody in Key Vault plus an offline recovery kit
Security alerts routed to on-call through an action group
Vaulted backup for the Data Lake and Azure Files; a restore test calendar per workload class

FACILITATOR ONLY | READ ALOUD IN THE DEBRIEF AT 0:49

The Attacker's Diary

When	Entry
Day minus 16	Someone in storage ran my quota tool. I had their session before their coffee cooled.
Day minus 14	I read everything. Three vaults. One of them has immutability switched on but not locked, which means it is switched on until I decide otherwise. The alerts go to a mailbox nobody opens. The runbook folder on the second file server has the passphrase in it. They wrote it down for me.
Day minus 3	I shortened retention on the big vault to seven days. Nothing refused me. Nothing called anyone.
Day minus 2	I deleted six backups to see what would happen. Six alerts fired into the mailbox. Nobody came.
Day minus 1	I switched soft delete off and purged the six. I switched immutability off on the research vault and deleted its backups; those will purge in two weeks. I removed the thirty-day policy on the Oracle container. It was never locked.
Day 0, 02:14	Everything at once. The file servers, the finance database, the backup server's local disks, twelve of their web machines. Then I deleted the rest of the VM backups, deleted the Oracle storage account, and deleted four containers from the data lake.
02:58	The library archive would not let me delete a thing. Twenty-five years, locked. I moved on.
03:00	I tried the MABS backups. They went to soft delete, not to the void. I was going to come back for that setting.
04:50	My account went dark. Someone woke up.

Facilitator: read it slowly and in first person. Then ask: which line would have been different with your design? Every team can now point at a card and a letter.

The as-is outcome

Asset	What happened	Recoverable?	Because
42 Azure VM backups (rsv-cus-infra-01)	Purged: 6 on Friday, 36 on Saturday	No	No immutability; soft delete was switched off first
12 encrypted Azure VMs	Encrypted through lateral movement	Rebuild only	Infrastructure as code can redeploy the machines; the data on them is gone
Research vaulted backups (bvault-cus-research-01)	Deleted into soft delete on Friday 01:50	Yes, until the 14-day clock runs out	The Backup vault's soft delete was still on
MABS and MARS data (rsv-cus-mabs-01)	Deleted into soft delete on Saturday 03:00	Yes, if undeleted in 14 days and the passphrase is found	The account was disabled before soft delete could be switched off; the passphrase was on FS-TC-02
Oracle RMAN images (stumnbkpimages01)	Policy removed Friday; account deleted Saturday	Best effort only	An unlocked policy does not protect the account; deleted-account recovery within 14 days is conditional
Research Institute North data lake	Four containers deleted	No	No soft delete, no vaulted backup, no copy anywhere
Azure Files shares (3)	Backup items deleted with the vault purge	No	Snapshot-only policy, no vaulted copy
Campus Libraries archive (stumnarchive340)	Delete attempts refused	Intact	Locked 25-year time-based policy from Session 2
FS-TC-01 to FS-TC-04, SQL-DEPT-03, ORA-FIN-01 and 02	Encrypted	Depends on the two rows above	Recovery runs through the MABS vault tier (slow) and the Oracle images (uncertain)

Use it like this: after the diary, show this page and let the room connect every row to a control letter. The two rows marked "Yes" are the ones a fast response saved. The "Intact" row is Session 2 paying off. Everything else is Monday's roadmap.